

CodeNotary 使用手册

演示站: <https://ara.sciba.cn> | 开源仓库: github.com/anita769/CodeNotary (系统本体)、github.com/anita769/codenotary-demo (GitHub 接入样例)

CodeNotary 是代码公证处: AI 或人写的代码, 经过「契约冻结 → 双盲修复/验证 → 三道确定性门禁 → 公证封印」再交付; 契约歧义、合并放行、经验转正三件事永远由人签署。本手册覆盖三条使用线, 全部以真实演示案例截图说明。

线	适用	终点
① GitHub 仓库接入	团队仓库的 PR 评审/合并把关	公证通过 → 负责人 merge
② 大厅上传 ZIP	手头有一段代码要公证 (不带仓库)	公证通过 → 下载修复好的文件
③ 纯问题工单	代码就在团队仓库里, 只报问题	公证通过 → 证书与证据包

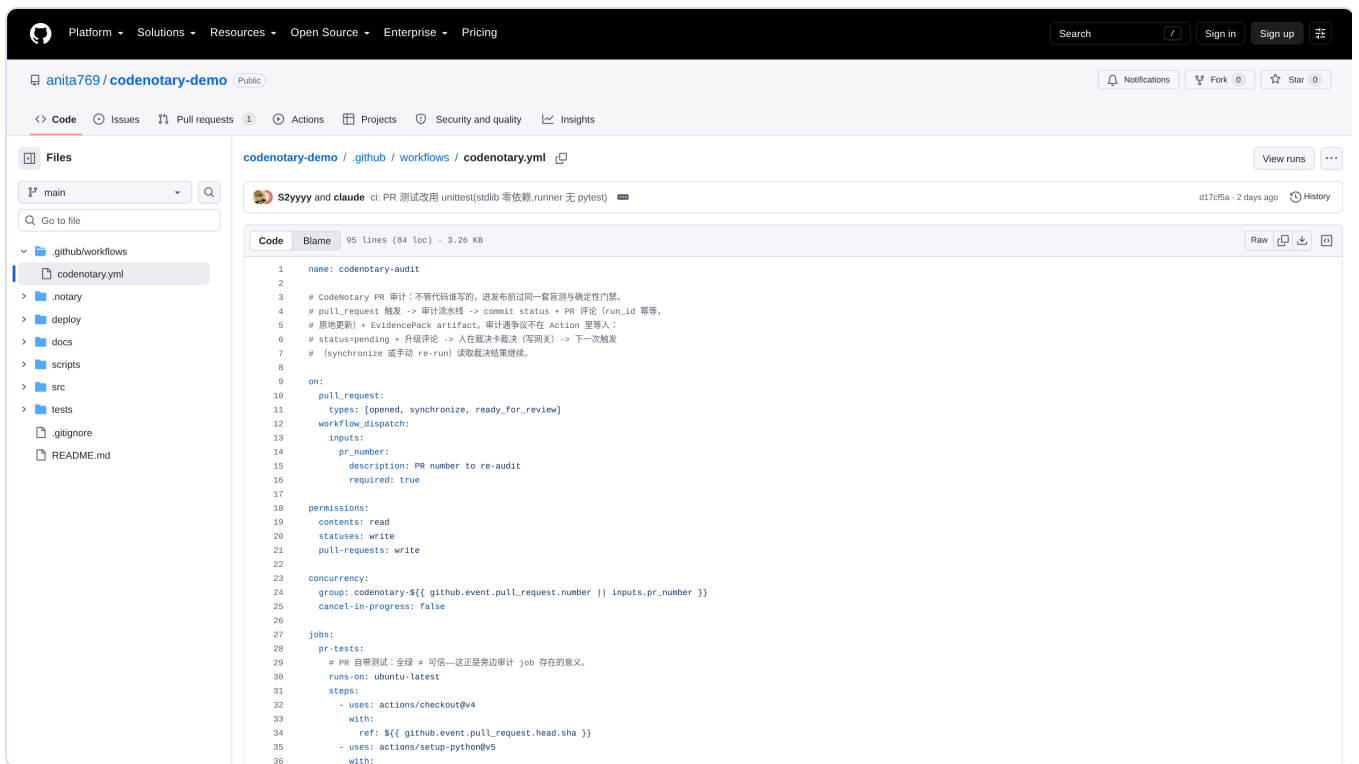
线 ① GitHub 仓库接入 (到 merge)

以公开样例仓 `codenotary-demo` 的 PR #2 为实例——它是这条线真实跑过的记录, 不是示意图。

1. 接入配置 (一次性, 四步)

以样例仓 `codenotary-demo` 为模板, 四个文件/设置各有分工:

① **workflow `.github/workflows/codenotary.yml`** (样例仓可直接抄) ——PR 打开、更新、手动重跑三个触发口; 两个 job 各司其职:



```
on:
  pull_request:
    types: [opened, synchronize, ready_for_review]
  workflow_dispatch:      # 手动 re-run：裁决落地后补跑

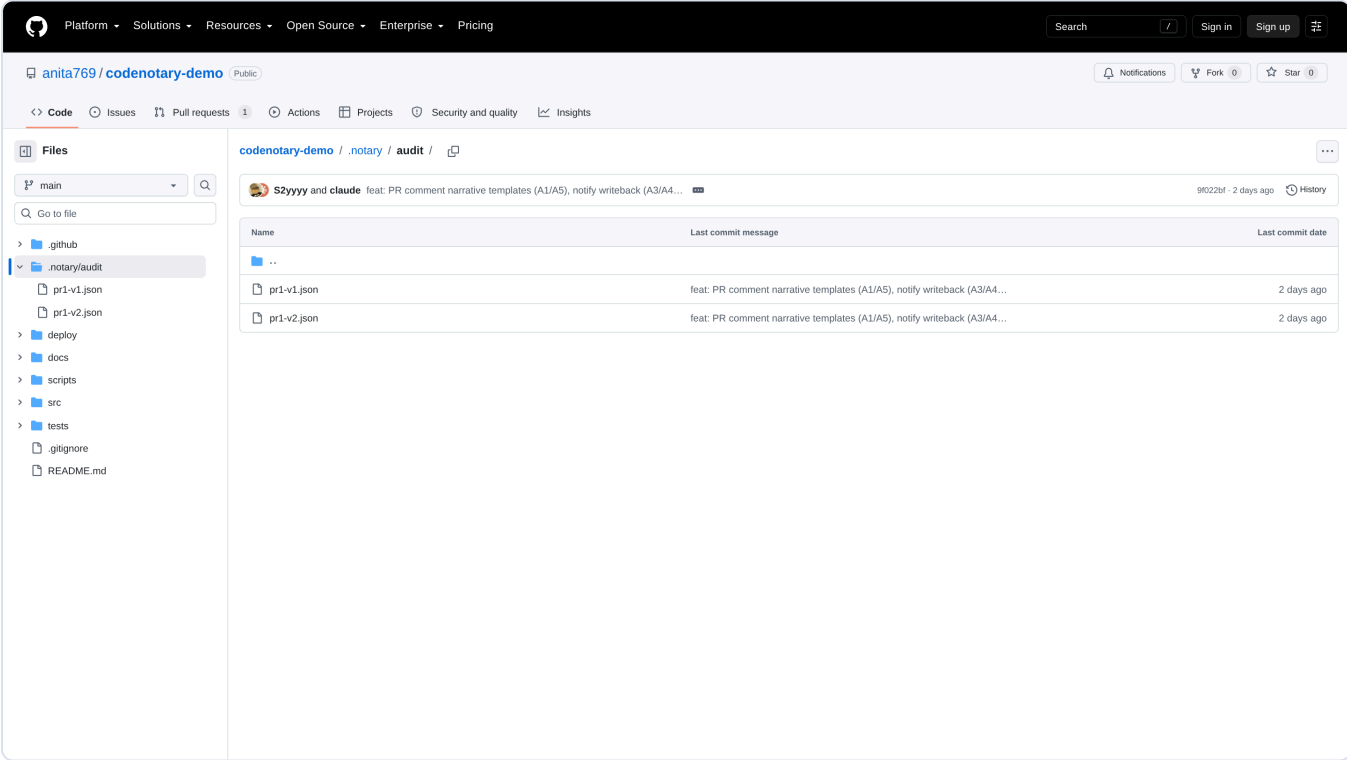
permissions:              # 最小权限：读代码、写状态、写评论
  contents: read
  statuses: write
  pull-requests: write

jobs:
  pr-tests:               # PR 自带测试：全绿 ≠ 可信——它只是对照组
    steps: [checkout, setup-python, python -m unittest discover -s tests -v]

  audit:                  # 公证 job：装网关 → 选 spec → 跑审计 → 传证据包
    steps:
      - git clone github.com/anita769/CodeNotary notary
      - git -C notary checkout ${vars.CODENOTARY_SHA || 'main'} # 钉版本
      - python scripts/ci_audit.py --spec .notary/audit/pr1-v1.json ...
      - upload-artifact: evidence-pack.zip # 自包含证据包, if: always()
```

要点：审计在 GitHub runner 上现场装一份钉死版本的网关（`CODENOTARY_SHA` 仓库变量），审计代码即法律，版本可复算；遇到争议不在 **Action** 里等人——状态置 pending、评论升级，人在裁决卡裁决，下一次触发自动继续。

② **审计 spec** `.notary/audit/*.json` ——告诉网关「这个 PR 审什么」：目标靶场、PR 文件到靶场文件的映射、工单原文（标题/现象/验收标准）、审计步骤。分支到 spec 的映射写在工作流里；没有 spec 的分支走「材料不足」快速路径，不会误报。

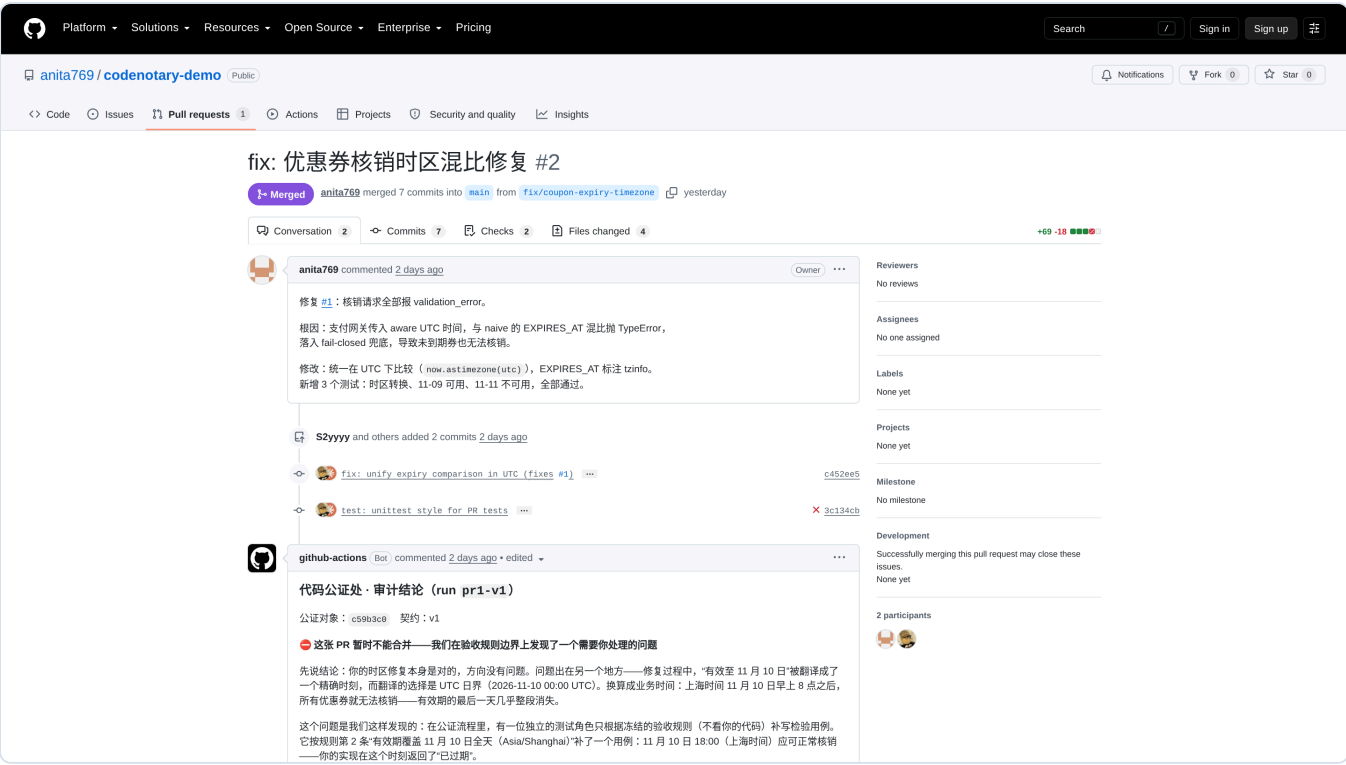


③ **回写脚本** `scripts/ci_audit.py`（纯标准库，唯一外部依赖是 `gh`）——幂等是设计核心：同一 `run_tag` 的评论原地更新，不会刷屏；重复触发产生并存的多版证据，永不覆盖。

④ **分支保护**：仓库 Settings → Branches → 给 main 加规则，必需检查填 `codenotary-audit`（并勾 `enforce admins`）。配完后：**不公证，合并按钮就是灰的**——这不是流程约定，是 GitHub 层面强制。

2. 开 PR，自动送审

开发者照常开 PR。Action 自动把补丁送审，公证结论以评论写回 PR：



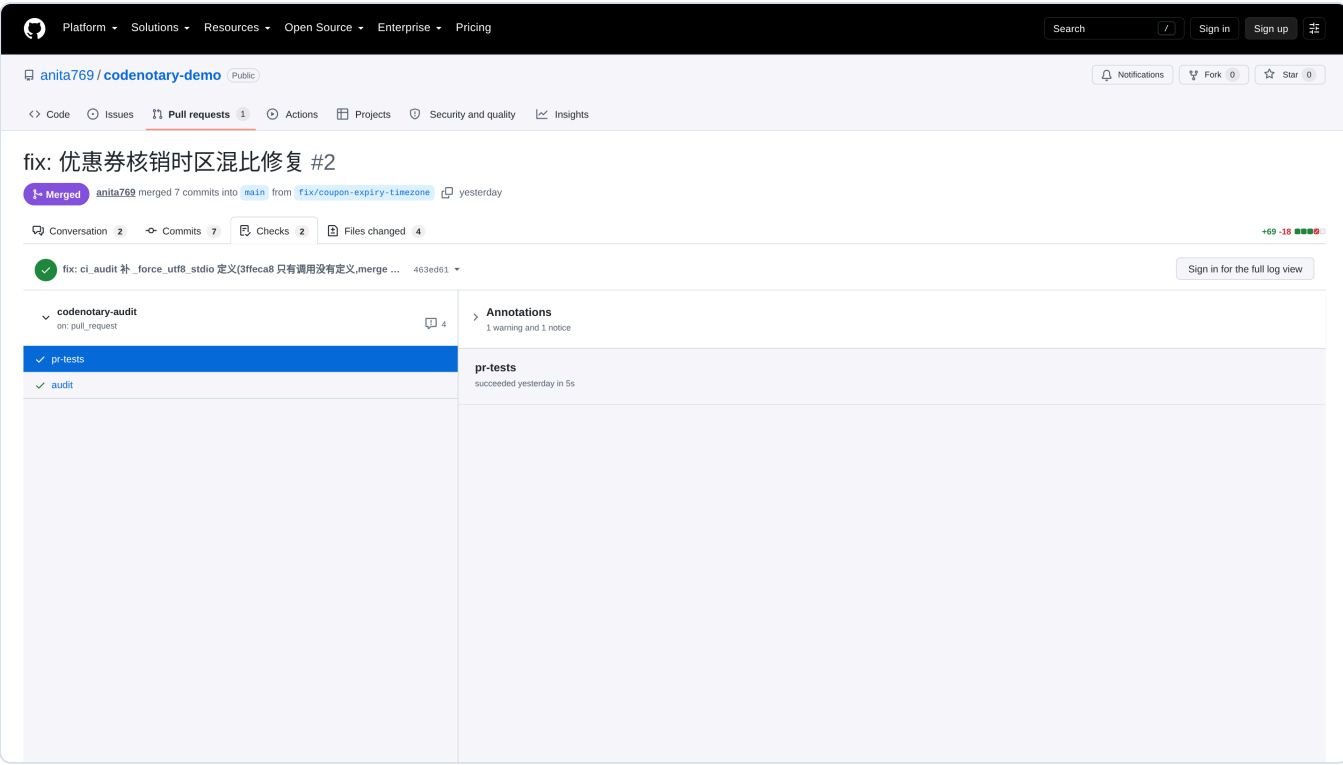
3. 红灯：审计评论讲清「为什么不能合并」

门禁不过时，评论不是一句「CI 失败」，而是完整叙事：结论、根因、是哪个盲测用例抓住的、你现在可以做什么。

（上图 PR #2 的首条审计评论即实例：时区修复本身正确，但「有效至 11 月 10 日」被翻成了 UTC 日界——最后一天晚高峰整段消失。）

4. 修复重审，全绿

作者按反馈修订后推送，Action 自动重审（同一工单幂等取号，两版证据并存永不覆盖）：



5. 负责人 merge

公证通过 ≠ 自动合并。系统的权力止于就绪意见——合并动作只属于负责人、在 GitHub 上完成：



(上图：v2 审计结论「公证通过，这张 PR 可以合并了」+ 三项检验全绿 + 负责人执行 merge。)

6. 证据包与离线复算

每次公证产出自包含证据包（代码快照、契约、门禁判定、trace、封印清单，Ed25519 签名）。任何人可离线复算，不必信任我们：

```
make verify EVIDENCE=evidence-pack.zip
```

复算对象：coupon_inhouse_v1

✓

 签名：Ed25519 有效（指纹 12b8d2feefbc1a00）

✓

 哈希链：18 个文件全部吻合

✓

 trace 前缀：前 54 行吻合（封印后追加 3 行，append-only 正常）

✓

 契约：frozen_hash 重算一致 2b2e10e6016da8cd...

✓

 门禁 TEST_PASS：重算 green（23 个测试） vs 封存 green

✓

 门禁 MUTATION：重算 score=1.00（杀 2/幸存 0/豁免 0）→ green vs 封存 green

✓

 门禁 CONVENTION：重算 green（0 findings）vs 封存 green

结论：

✓

 证据复算一致—哈希链/契约/门禁 verdict 全部可重现

线② 大厅上传 ZIP（到下载修复好的文件）

适用：手头有一段代码要公证，不想接仓库。以演示案例（优惠券核销服务）为实例。

1. 附 ZIP 描述问题

办事大厅输入框写一句话，旁侧附上 ZIP（源码 + 测试）：

CodeNotary 公证处

任务看板

办事大厅

Skill 看板

导览台

办事大厅

送审 / 求修

一句话描述问题，可附 ZIP（有代码要审）；接待员帮您起草公证申请，您确认后才取号。

优惠券核销在有效期内报销，附带了源码和基线测试，请公证这份代码

Choose File coupon-upload.zip

请接待员起草

我的任务

优惠券没到期就核销不了
等待人工裁决

优惠券有效期至 11 月 10 日,但没到期就核销不了
已发布

SpecifierSet 的 <= / >= 比较未忽略候选版本的 local 段（违反 PEP 440）
已发布

==X.* 前缀匹配在 specifier 带 epoch 且候选 release 段更细时误判为不匹配
已发布

优惠券没到期就核销不了 · 等待人工裁决

进度

等待人工裁决中

发生了什么 任务已升级，系统按设计暂停

意味着什么 这不是报错，是公证处把只能人答的问题交给给人

您能做什么 您可以在下方追问任何证据细节

证据在哪 —

下一步 裁决落地后自动继续

进度

已受理，取号成功

发生了什么 收到送审「优惠券没到期就核销不了」，登记为 coupon_tour

意味着什么 您的请求已进入公证流水线，按序办理

您能做什么 无需操作，进展会主动通知您

证据在哪 issue.json

下一步 分诊与检脸自动进行

回顾

异议已受理（这通读就是为这件事存在的）

发生了什么 您提出的异议：契约断言 2 把「有效期至 11 月 10 日」解读为含当天至 24:00——工单只说有效期至 11 月 10 日，没说按哪个时区的自然日、当天算不算。这版解读的需求依据是什么？

意味着什么 争议对象是契约条款的立项依据，系统不会自问自答；已升级人工裁决，任务保持阻塞，无人可以绕过

您能做什么 您不需要做任何等待操作，结果会通知您（含结论、理由、对您的要求）

证据在哪 dispute.json

下一步 裁决人将在裁决工作区处理

待办

需要您处理：检验未通过

发生了什么 测试门禁判定不通过：共执行 23 个检验用例，存在未通过项

意味着什么 按当前验收规则，这次改动暂不可放行。机器修实现、人裁决意图——系统可在隔离环境自主试修候选补丁，是否写回您的仓库由您授权

您能做什么 您可以：①按修复指引改完重新送审；②若认为规则本身缺乏依据，提出异议（notary dispute）

证据在哪 verdicts/test_pass.json

下一步 等您修复或异议；不处理任务就停在这里

追问

这里只帮您留痕记录、摆事实；不产生任何状态变更，正式动作请走卡片。

2. 接待员起草公证申请

点「请接待员起草」——接待员会真的读你的代码：下图草稿中它已经分析出 `expires_at` 是 naive 本地时间、与支付网关的 aware UTC 混比抛 `TypeError`。检查草稿，确认取号：

办事大厅

送审 / 求修

一句话描述问题，可附 ZIP（有代码要审）；接待员帮您起草公证申请，您确认后才取号。

优惠券核销在有效期内报错，附带了源码和基线测试，请公证这份代码

Choose File

coupon-upload.zip

请接待员起草

公证申请草稿（请检查，确认才取号）

优惠券没到期就核销失败的问题公证

工单反馈优惠券有效至 11 月 10 日，但在到期前核销就报错。代码中 `expires_at` 是 naive 本地时间，而支付网关传入的 `now` 是 aware UTC 时间，Python 3 在 naive 与 aware `datetime` 混比时直接报 `TypeError`，导致核销流程中断，影响用户正常使用优惠券。

1) 在到期时间之前核销优惠券应返回 `ok` 为 `True` 且不抛异常
2) 在到期时间之后核销优惠券应返回 `ok` 为 `False`
3) 核销逻辑对 naive 与 aware 时间输入都能正确处理，不再出现 `TypeError`
A: 如题所述，`datetime.datetime.strptime` 函数只能处理 naive 的日期时间

确认无误，取号送审

我的任务

优惠券没到期就核销不了
等待人工裁决

优惠券有效至 11 月 10 日,但没到期就核销不了
已发布

SpecifierSet 的 `<=/>=` 比较未忽略候选版本的 `local` 段（违反 PEP 440）
已发布

`==X.*` 前缀匹配在 `specifier` 带 `epoch` 且候选 `release` 段更细时误判为不匹配
已发布

优惠券没到期就核销不了 - 等待人工裁决

进展 等待人工裁决中

发生了什么 任务已升级，系统按设计暂停

意味着什么 这不是报错，是公证处把只能人答的问题交给给人

您能做什么 您可以在下方追问任何证据细节

证据在哪 —

下一步 裁决落地后自动继续

进展 已受理，取号成功

发生了什么 收到送审「优惠券没到期就核销不了」，登记为 `coupon_tour`

意味着什么 您的请求已进入公证流水线，按序办理

您能做什么 无需操作，进展会主动通知您

证据在哪 `issue.json`

下一步 分诊与检验自动进行

进展 异议已受理（这通道的就是为这件事存在的）

发生了什么 您提出的异议：契约断言 2 把「有效至 11 月 10 日」解读为含当天至 24:00——工单只说有效至 11 月 10 日，没说按哪个时区的自然日、当天算不算。这版解读的需求依据是什么？

意味着什么 争议对象是契约条款的立项依据，系统不会自问自答；已升级人工裁决，任务保持阻塞，无人可以绕过

您能做什么 您不需要做任何等待操作，结果会通知您（含结论、理由、对您的要求）

证据在哪 `dispute.json`

下一步 裁决人将在裁决工作区处理

进展 您需要处理：检验未通过

发生了什么 测试门禁判定不通过：共执行 23 个检验用例，存在未通过项

意味着什么 按当前验收规则，这次改动暂不可放行。机器修实现、人裁决意愿——系统可在隔离环境自主试修候选补丁，是否写回您的仓库由您授权

您能做什么 您可以：①按修复指引改完重新送审；②若认为规则本身缺乏依据，提出异议（*notary dispute*）

证据在哪 `verdicts/test_pass.json`

下一步 等您修复或异议；不处理任务就停在这里

追问

这里只帮您查落盘记录、摆事实；不产生任何状态变更。正式动作请走卡片。

例：失败的是哪个场景？契约哪一条？

问

3. 取号成卡

确认后任务出现在「我的任务」，右侧自动展开信封时间线——每一封信写清发生了什么、意味着什么、证据在哪、下一步：

CodeNotary 公证处任务看板办事大厅Skill看板导览台

办事大厅

送审 / 求修

一句话描述问题, 可附 ZIP (有代码要审); 接待员帮您起草公证申请, 您确认后才取号。
例: 优惠券有效至 11 月 10 日, 但没到期就核销不了

Choose FileNo file chosen

请接待员起草

我的任务

优惠券核销在有效期内报错的公证

已受理, 排队分诊

优惠券没到期就核销不了

等待人工裁决

优惠券有效至 11 月 10 日, 但没到期就核销不了

已发布

SpecifierSet 的 <= / >= 比较未忽略候选版本的 local 段 (违反 PEP 440)

已发布

== X.* 前缀匹配在 specifier 带 epoch 且候选 release 段更细时误判为不匹配

已发布

优惠券核销在有效期内报错的公证 · 已受理, 排队分诊

进度

已受理, 取号成功

发生了什么收到送审「优惠券核销在有效期内报错的公证」, 登记为 intake_e964110917

意味着什么您的请求已进入公证流水线, 按序办理

您能做什么无需操作, 进展会主动通知您

证据在哪issue.json

下一步分诊与检验自动进行

追问

这里只帮您查落盘记录、摆事实; 不产生任何状态变更。正式动作请走卡片。

例: 失败的是哪个场景? 契约哪一条?

问

4. 流水线与裁决

流水线棒次与线 ① 完全相同（检疫→分诊→根因→契约→修复→盲测→三门禁）：

CodeNotary 公证处任务看板办事大厅Skill看板导览台

优惠券没到期却核销不了

状态 盲测编写中 · Run coupon_tour

验收: 运行中 合并: 未开始 发布: 未开始

哨兵完成

分诊完成

根因完成

契约完成

作者完成

盲测完成

门禁进行中

最终验收待执行

合并待执行

概览

验收契约

验证结果

Agent 运行

证据

审计记录

盲测编写中

当前状态

10 网关调用

1.2 分钟 遇到超时 (含等待)

1 对批环迭代

0 人工介入

4 Skill 咨询

0 超权拒绝

0/2 重修轮次

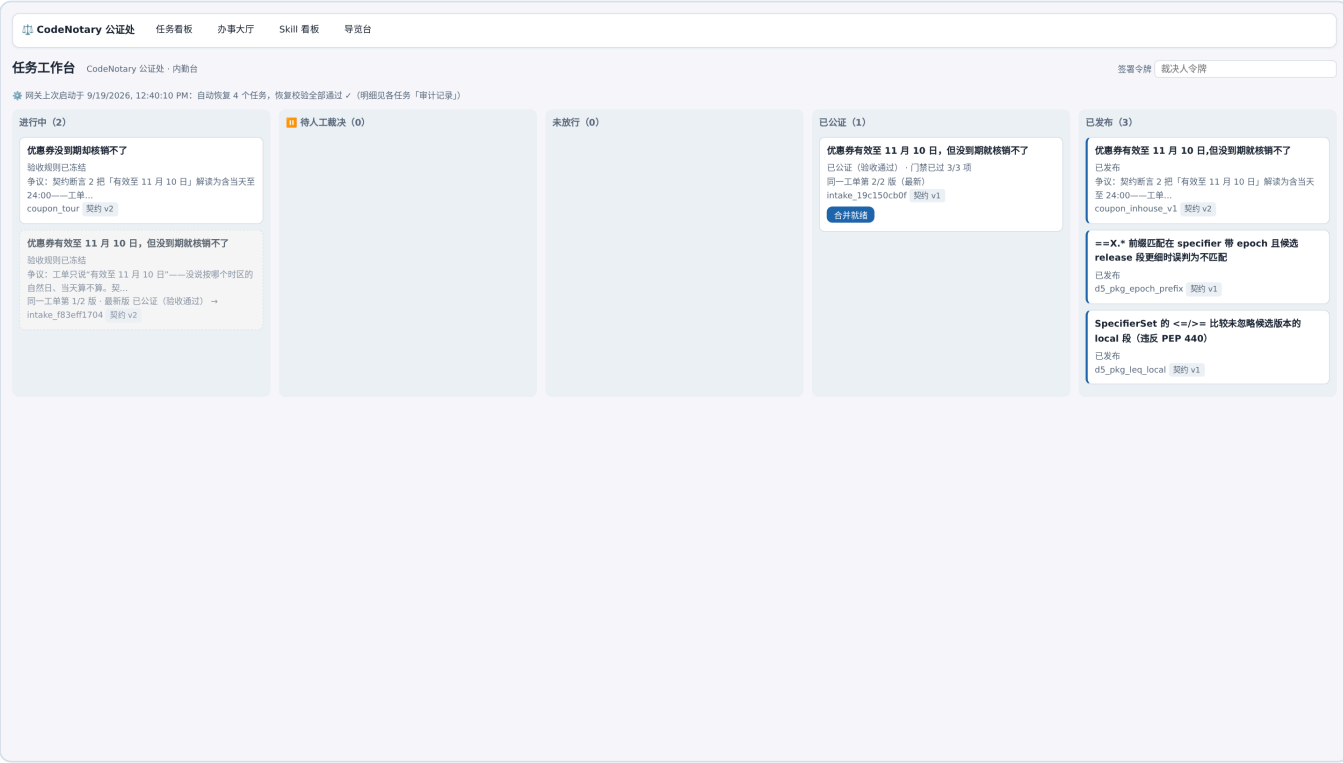
状态流转 (14 态状态机)

RECEIVED → SCREENED → TRIAGED → DIAGNOSED → CONTRACTED → AUTHORIZING → TESTING → GATING → NOTARIZED → RELEASED

处理过程

环节	要点	状态	下一步
分诊 · 任务拆解与路由	受理结论: 受理 检验范围: coupon.py	完成	根因分析 ▶ 详情
根因分析 · 根因定位	根因: 时区混比: expires_at 为模块级 naive datetime, 支付网关传入 aware UTC, Python3 混比抛 TypeError, 落入 redeem 的 fail-closed 兜底, 全部核销请求返回 validation_error——未到期也无法核销。 修复假设: 统一 aware 化后报 UTC 比较; 失效边界按业务自然日口径在契约中形式化。	完成	冻结验收规则 ▶ 详情
契约 · 验收规则 v1	断言 1: 所有过期比较必须在 UTC 下进行, naive/aware 混比已修复 断言 2: 核销有效期覆盖至 2026-11-10 24:00 (Asia/Shanghai 业务自然日, 含当天); 之后失效	已冻结	盲测独立验证 ▶ 详情
盲测 · 独立测试设计 (未见实现代码)	生成测试文件: test_blind_contract.py 验证目标: 仅依据冻结契约编写用例, 覆盖规则要求的边界场景	完成	确定性门禁检验 ▶ 详情

契约条款依据不足时流水线挂起等人工裁决；裁决卡上双方立场、假设、证据分列，签署即留痕：



5. 交付：逐文件查看、验哈希、下载

公证通过后进「任务详情 → 证据」页：每个环节的产出逐条列出，全部带 SHA-256 封印，点击文件名即可查看内容并现场校验哈希：

CodeNotary 公证处

任务看板

办事大厅

Skill 看板

导览台

优惠券有效期至 11 月 10 日,但没到期就核销不了

状态 已发布 · Run coupon_inhouse_v1

验收: 通过

合并: 已执行

发布: 已发布

● 哨兵 完成

—

● 分诊 完成

—

● 根因 完成

—

● 契约 完成

—

● 作者 完成

—

● 盲测 完成

—

● 门禁 完成

—

● 人工裁决 完成

—

● 最终验收 完成

—

● 合并 完成

概览

验收契约

验证结果

Agent 运行

证据

审计记录

证据文件均带 SHA-256 封印; 点击文件名查看内容并现场校验哈希。

文件

说明

分诊 · 任务拆解与路由

► 技术详情 (原始数据)

根因分析 · 根因定位

► 技术详情 (原始数据)

契约 · 验收规则 v2

► 技术详情 (原始数据)

盲测 · 独立测试设计 (未实现代码)

► 技术详情 (原始数据)

门禁 · 规范检查

► 技术详情 (原始数据)

门禁 · 变异测试

► 技术详情 (原始数据)

门禁 · 测试门禁

► 技术详情 (原始数据)

争议 · 修复方异议 (正式通道)

► 技术详情 (原始数据)

人工裁决 · #1 修订契约

► 技术详情 (原始数据)

验收 · 公证书

▼ 技术详情 (原始数据)

{
 "certificate": "certificate.md",
 "manifest": "manifest.json",
 "signature": "evidence/manifest.sig.json"
}

直接下载：任务工作台「已发布」列的卡片上有「**↓ 交付物**」按钮——交付卡列出修复好的文件（如 `work/author_wt/coupon.py`）与公证书，逐件下载；每个文件标注 SHA-256 指纹，与封印清单（manifest）逐项可核对：

CodeNotary 公证处

任务看板

办事大厅

Skill 看板

导览台

任务工作台

CodeNotary 公证处 · 内勤台

签署令牌

裁决人令牌

🌟 网上次启动于 9/19/2026, 12:40:10 PM: 自动恢复 4 个任务, 恢复校验全部通过 ✓ (明细见各任务「审计记录」)

进行中 (1)

待人工裁决 (0)

未放行 (0)

已公证 (1)

已发布 (4)

优惠券有效期至 11 月 10 日, 但没到期就核销不了

验收规则已冻结

争议: 工单只说“有效至 11 月 10 日”——没说按哪个时区的自然日、当天不算。契...

同一工单第 1/2 版 · 最新版 已公证 (验收通过) →

intake_f83eff1704 契约 v2

交付物 · coupon_tour_58dab9

下载到的每个文件都带 sha256 指纹, 与封印清单 (manifest) 逐项可核对。

修复后的代码

📄 coupon.py

work/author_wt/coupon.py · 1.4 KB · sha256 1e875a4fae0e2f87...

下载

证书

📄 公证书 certificate.md

绑定代码与契约双版本, 可独立复算

下载

整包证据 (含测试、门禁输出、签名) 可用仓库里的 make verify 独立复算。

优惠券有效期至 11 月 10 日,但没到期就核销不了

已发布

争议: 契约断言 2 把「有效至 11 月 10 日」解读为含当天至 24:00——工单...

coupon_inhouse_v1 契约 v2

↓ 交付物

优惠券有效期至 11 月 10 日, 但没到期就核销不了

已发布

争议: 契约断言 2 把「有效至 11 月 10 日」解读为含当天至 24:00——工单...

coupon_tour_58dab9 契约 v2

↓ 交付物

==X.* 前缀匹配在 specifier 带 epoch 且候选 release 段更细时误判为不匹配

已发布

d5_pkg_epoch_prefix 契约 v1

↓ 交付物

SpecifierSet 的 <= / >= 比较

也可以通过文件接口取出——返回内容 + 声明哈希 + 现场复算哈希（加 `?download=1` 则直接下载原始文件）：

```
curl "https://ara.sciba.cn/api/file/<任务号>/work/author_wt/coupon.py"
# 返回：文件内容 + 封印清单里的声明哈希 + 现场复算哈希（两者相等即未被篡改）
curl -OJ "https://ara.sciba.cn/api/file/<任务号>/work/author_wt/coupon.py?download=1"
```

要拿走完整证据包离线复算，用线 ① 第 6 节的 `make verify`。

线 ③ 纯问题工单（内部修复）

代码本就在团队仓库里，工单只描述问题——不需要上传任何东西。

团队的代码放在哪：部署网关时，把业务代码放进网关的靶场目录（`tools/notary_target/`），并在靶场注册表里登记一行映射（靶场名 → 源文件 + 基线测试）。

修复发生在哪：绝不在你的正式仓库里直接改。每次任务在 `runs/<任务号>/work/` 下开隔离工作区，修复、盲测、门禁全部在隔离区完成；公证通过后交付物进证据包，**写回正式仓库由负责人授权**——系统的权力止于你的仓库之外。

完整操作见《体验版操作手册》（导览台 <https://ara.sciba.cn/tour> 四步动线：提交问题 → 看流水线 → 亲手裁决 → 交付证书与修复文件）。

附录 • 自行部署：密钥与令牌配置

```
# 1. 封印签名密钥对（每次封印用它签名，公钥供任何人验签）
mkdir -p keys
openssl genpkey -algorithm ed25519 -out keys/notary_ed25519.pem
openssl pkey -in keys/notary_ed25519.pem -pubout > keys/notary_ed25519.pub
chmod 600 keys/notary_ed25519.pem

# 2. 令牌签发密钥与裁决令牌（console 的写操作凭它）
python3 tools/notary_token.py mint --sub 张三 --role adjudicator \
    --scope adjudicate --ttl 86400 --secret-file keys/token_secret

# 3. LLM key（大厅接待员用，任何 OpenAI 兼容服务）
export CODENOTARY_LLM_KEY=sk-...

# 4.（接 GitHub 时）合并就绪卡核对真实 check 状态
export GH_TOKEN=ghp-...
```

console 启动时带上令牌密钥：`python3 tools/notary_console.py --token-secret keys/token_secret`。私钥与 `token_secret` 已在 `.gitignore` 中，不要提交。

附录 · 三条线的共同终点

不管哪条线，终点都是同一份公证：**证书（契约哈希 + 门禁判定 + 人工介入次数） + 签名封印的证据包 + 可离线复算**。验收、合并、发布是三件事——系统出验收结论，合并归负责人，发布走你原有的流程。